I – Sécurité : Introduction

© PSO - 2023

La sécurité informatique

- La confidentialité de mes données
- L'intégrité de mes données
- La continuité de service

En anglais, le terme CIA (Confidentiality, Integrity and Availability)

© PSO - 2023

Principes de la sécurité

La sécurité informatique ou l'espionnage repose sur les mêmes principes :

- Le secret
- La compartimentation
- L'authentification
- L'accréditation et la classification des documents
- La minimisation
- La surveillance
- La désinformation
- La formation, l'information , les sanctions

© PSO - 2023

Moyen de la sécurité informatique 1/2

- **La cryptologie** : Cacher des informations transitant sur les réseaux ou stockées dans des fichiers. La cryptologie est aussi utilisée dans la vérification de l'intégrité des données ou l'authentification des individus ou des services.
- **La sécurité physique** : enfermé ses serveurs à clé.
- **Systèmes d'authentification** : La connaissance d'un password est le moyen d'identification informatique le plus usuel. Les systémes biométrique (iris,empreinte..) sont de plus en plus utilisé.

© PSO - 2023

Moyen de la sécurité informatique 2/2

- **Les Droits**: les droits associés aux fichiers limite leur accès à telle ou telle personne (ou groupes).
- **Les sommes de contrôle** : Vérifient l'intégrité des fichiers. La présence de logiciels malveillant (virus,rootkit…) est principalement mise en évidence par cette technique.
- **Les pare-feu** : filtre les paquets réseaux. C'est un outils de protection indispensable.
- **Les sauvegardes**. Suite à une attaque on peut perdre des données vitales. La sauvegarde régulière des données est le seul recours.
- **L'audit des principaux événements** (connexion réussie, échouée..) du système. Il garantit le suivit des règles de sécurité et détecte es tentatives d'intrusion.

© PSO - 2023

Différents secteurs de la sécurité

- **La sécurité global**. Elle s'occupe de la sécurité des locaux, des documents papier, du personnel. Par ses objectif et ses moyens, elle est proche de la sécurité militaire.
- **La sécurité réseau**. Le responsable de la sécurité réseau est le plus souvent le responsable de la sécurité informatique tout cours. Son service est responsable des pare-feu, techniques anti-intrusion réseau, et du choix global de sécurisation.

© PSO - 2023

Différents secteurs de la sécurité

- **La sécurité des serveurs** : Les administrateurs doivent connaitre les techniques de sécurisation offertes par les OS et par les applications pour mettre en œuvre les politiques édictées par le responsable de la sécurité.
- **La sécurisation des applications** : Les responsables d'appli doivent non seulement mettre en place et gérer leur application, mais aussi veilleur à leur sécurisation. Donner les accréditations aux utilisateur
- **La sécurisation des postes de travail**

© PSO - 2023

Les Attaques 1/4

- **Exploit** : Un exploit est un programme qui exploite une faille d'un logiciel. Au minimum entraine un **deni de service** mais au pire permet le **contrôle du logiciel ou du système**.

Les principales techniques utilisées par les exploits:

- Le dépassement de tampons (buffer Overflow)
- L'injection de code (code injection)
- L'injection SQL

- **L'usurpation d'adresse IP** (IP Spoofing)

IP Spoofing consiste à générer des paquets IP qui semble pour la cible provenir d'un poste accrédité

© PSO - 2023

Les Attaques 2/4

- **Session Hijacking** : Forme particuliere IP Spoofing. Le pirate se substitue à un poste après sa phase d'authentification
- **Replay** : Consiste à enregistrer des informations d'authentification et à les réutiliser ultérieurement lors d'une autre session
- **L'attaque de l'homme du milieu** (Man in the middle) : Forme particulière IP Spoofing. Le pirate joue l'intermediaire entre le client et le serveur. Il est le serveur vis-à-vis du client, et il est le client vis-à-vis du serveur. Il peut ainsi récolter des informations confidentielles étant donné qu'il a accès à tout le dialogue des correspondants

© PSO - 2023

Les Attaques 3/4

- Déni de service (DOS: Denail Of Service)

  Cette attaque consiste à rendre inutilisable le système cible. Soit en le surchargeant de requêtes, soit en le faisant « planter »
- Phishing : Acquérir de manière frauduleuse (via une réponse à un mail) des informations sensibles (mot de passe, @ IP)
- Pharming Consiste à rediriger le trafic d'un serveur vers un autre dont on a le contrôle.

© PSO - 2023

Les Attaques 4/4

- **L'attaque des mots de passe**

Un des points faibles des protections informatique est l'usage de mots de passe. 2 Technique permettent de les trouver (+ ou – rapidement)

1. L'attaque du dictionnaire : on compare le mot de passe chiffré au chiffrement d'une base préétablie (appelée dictionnaire) de mots de passe.
2. L'attaque exhautive : on essaye de chiffrer toutes les combinaisons possibles des caractères entrant dans la composition d'un mot de passe. Cette attaque n'est possible que si les mot de passe sont courts (< 8 caractères)

© PSO - 2023

Logiciels malveillants 1/3

- **Virus** : morceau de code inséré dans un logiciel de telle façon que quand le code du logiciel est exécuté, celui du virus l'est également. Le virus essaye également d'infecter d'autres logiciels sains. Le code inséré nuit généralement au fonctionnement du système.
- **Ver** (Worm) Logiciel malveillant qui s'auto réplique, le plus souvent en envoyant des copies de lui même sur d'autres ordinateurs. Contrairement à un virus , il n'est pas associé à un autre logiciel.

© PSO - 2023

Logiciels malveillants 1/3

- **Cheval de Troie** (Trojan Horse) : Morceau de code introduit dans un autre logiciel et qui effectue des action maligne dans certaine circonstances. A la différence d'un virus, il ne peut pas se reproduire par lui-même. C'est la recopie du logiciel hôte qui assure sa reproduction.
- **Logiciel Espion** (Spyware) : Logiciel qui s'installe sur un système dans le but de collecter des informations. Ces informations sont le plus souvent récoltées par réseau.

© PSO - 2023

Logiciels malveillants 1/3

- **Rootkit** : Ensemble de commande qui se substitue aux commandes système (netstat…)

  Un Rootkit est utilisable à partir d'une porte dérobée après qu'une intrusion ait réussi. L'objectif est le maintien du pirate sur le système sans que l'on puisse détecter sa présence.
- **Porte dérobée** (BackDoor) : C'est un accès secret à un logiciel ou au système. Seul le pirate en a la connaissance et l'usage.

© PSO - 2023

Les politiques de sécurité

- 1er étape : Identifier ce qu'il faut protéger
- 2e étape : Analyser les risques
- 3e étape : Pondérer les risques
- 4e étape : Evaluer les contraintes
- 5e étape : Choisir les moyens
- 6e étape : Adopter la politique de sécurité
- 7e étape : Tester

© PSO - 2023

Etablir une politique de sécurité : 1/7

Identifier ce qu'il faut protéger

- Quels réseaux, ordinateurs, données. Ceci passe éventuellement par un classification des documents informatiques en Top secret, secret, confidentiel, public. Certaines données publiques doivent éventuellement être protégées : soit de leur destruction, soit de leur altération.
- Les postes seront classés en Bastions (serveurs devant être hyper protégés), poste sensible ou ordinateurs à accès libre.

© PSO - 2023

Etablir une politique de sécurité : 2/7

Analyser les risques

- On commence par analyser l'existant et à mettre en évidence les risques potentiels. C'est ce que l'on appelle réaliser un audit de survol. Pour évaluer les risques, on se base sur des scénarios qui sont construits à partir des attaques classiques. On peut réaliser des essaies d'intrusion.

© PSO - 2023

Etablir une politique de sécurité : 3/7

Pondérer les risques

- La plupart des société sont confrontées aux mêmes risques. Mais leur taille, les conditions d'exploitation ou leur métier font qu'un même risque n'a pas la même importance.
- Par exemple le risque d'avoir un employé malhonnête dans une entreprise de 20 personnes est plus faible que dans une multinationale. Il faut pondérer les risques :
- **Risque = impact * probabilité**

© PSO - 2023

Etablir une politique de sécurité : 4/7

Evaluer les contraintes

- Il faut tenir compte des contraintes
  - L'existant (matériels, logiciels, personnel, locaux)
  - Le budget
  - Le temps
- Il est important d'établir un budget de la sécurité et de mettre en regard la protection pondérée qu'elle apporte. (C-A-D perte en euros qu'elle évite) C'est le même raisonnement que l'on suit quand on s'assure.

© PSO - 2023

Etablir une politique de sécurité : 5/7

Choisir les moyens

- Les moyens de sécurisation : élément clé de la sécurité. (cryptographie, sécurisation des serveurs et des postes de travail, authentification des utilisateurs et des applications, les raccordements aux réseaux locaux ou distants, les routeur, les pare-feu, les VPN, les anti-virus, les politiques d'acquisition de matériels et de logiciels…
- Les moyens de détection d'intrusion

© PSO - 2023

Etablir une politique de sécurité : 6/7

Adopter la politique de sécurité

- Il faut une politique de sécurité. Une mauvaise politique sera toujours préférable à pas de politique du tout. Et il faut nommer un responsable, le monsieur sécurité.
- Dans une structure modeste, c'est le plus souvent le responsable réseau qui sera choisi

© PSO - 2023

Etablir une politique de sécurité : 7/7

Tester

- Après avoir adopté et mis en place une politique de sécurité, il faut d'assurer par un audit externe.
- L'élément clé de cet audit consiste, comme dans la deuxième étape, à réaliser des intrusions et à démontrer la résistance du système face à des scénario à risque

© PSO - 2023

Conduite à tenir en cas d'incident

1. Evaluer l'importance de l'incident et sa nature. Evaluer la solution de débrancher l'ordinateur réseau
2. Constituer un dossier d'analyse(qui peut aussi servir de dossier de preuves) et diagnostiquer le problème principalement en étudiant les logs. L'idéal est de faire une copie ou sauvegarde du système infecté (ce qui est facile s'il fonctionne en machine virtuelle)
3. Avertir éventuellement le CERT autorisés , la direction, utilisateurs
4. Réparer les système, reprendre l'activité
5. Evaluer les dommage, couts de l'incident. Document l'incident.
6. Vérifier s'il n'est pas nécessaire de modifier les stratégies et les moyens de sécurité

© PSO - 2023

Les erreurs à ne pas commettre

1. Panique
2. Ne pas avoir de plan de réponse aux incidents
3. Résoudre le problème sans essayer de la comprendre

Prévoyance

1. Constituer une équipe de réponse aux incidents (CERT: Computer Emergency Response Team)
2. Rassembler les information nécessaire (Coordonnées du FAI, du correspondant CERT : en France c'est le CERT-FR)
3. Prévoir des checklists pour diagnostique les problèmes
4. Prévoir un plan de reprise d'activité (sauvegarde…)

© PSO - 2023